



GAP ANALYSIS DOCUMENT

**FAST-NUCES Islamabad — Accounting
& Finance (AnF) Department**

Version: 1.0

Date: 2025

Prepared By: Ahmed

Course: Information Assurance

Contents

1. Introduction	3
2. Gap Analysis Methodology	3
3. Summary of Findings (Updated)	4
4. UPDATED GAP ANALYSIS TABLE (ISO 27001:2022 + Annex A Controls)	5
5. Key High-Priority Gaps (Updated Summary)	8
6. Updated Remediation Plan	8
7. Conclusion	9

1. Introduction

This updated Gap Analysis Document evaluates the FAST-NUCES A&F Department's current security posture against **ISO 27001:2022 standards and Annex A controls**, incorporating new departmental findings from the HOD, IT staff, and record assessment forms.

The analysis now includes risks related to:

- Exam paper handling
- Lab PC misuse
- Cloud storage misconfigurations
- System logging gaps
- Unlicensed software
- Student access issues
- Weak password practices
- Malware incidents
- Backup failures

This version reflects the **most accurate and complete security evaluation** of the A&F Department.

2. Gap Analysis Methodology

We assessed each ISO 27001:2022 control using the following criteria:

- **Compliant** – Fully implemented
- **Partially Compliant** – Exists but insufficient
- **Non-Compliant** – Missing controls
- **Not Applicable** – Outside the A&F scope

Each finding includes:

- Gap description
- Recommended action
- Priority level (High / Medium / Low)

3. Summary of Findings (Updated)

Area	Status
Governance & ISMS Structure	Partially Compliant
Access Control	Non-Compliant / High Gap
Asset Management	Partially Compliant
Physical Security	Partially Compliant
Cloud Security	Non-Compliant / High Gap
Logging & Monitoring	Non-Compliant / Medium-High Gap
Cybersecurity & Malware Protection	Partially Compliant
Software Licensing	Non-Compliant
Business Continuity	Partially Compliant
Supplier/Vendor Security	Partially Compliant

Most Serious Gaps Identified

(from PDF pages 9–12)

- No MFA (email & ERP)
- Weak password practices
- USB ports unrestricted
- Unencrypted laptops & payroll files
- Cloud storage & sharing misconfigurations
- Lack of log review
- Exam paper security gaps
- Student misuse of lab PCs
- Unlicensed/illegal software installs
- No vendor security review

- Outdated antivirus & patching
- Weak Wi-Fi security

4. UPDATED GAP ANALYSIS TABLE (ISO 27001:2022 + Annex A Controls)

Clean tabular format — ready for Word/Excel

Clause / Control	Requirement	Current Status	Gap Description	Recommended Action	Priority
A.5.1 Policies	Org-wide policies documented	Partially Compliant	Policies exist but not enforced or updated	Update & enforce IS policies	Medium
A.5.10 Acceptable Use	Rules for device/network use	Partially Compliant	No formal acceptable use policy	Draft Acceptable Use Policy	Medium
A.5.17 Authentication Info	MFA & secure authentication	Non-Compliant	Email & ERP have no MFA	Implement MFA	High
A.5.18 Awareness & Training	Staff cybersecurity training	Non-Compliant	No training conducted; phishing incidents	Conduct quarterly training	High
A.5.20 Segregation of Duties	Prevent conflict of interest	Partially Compliant	Vendor payments lack proper separation	Enforce segregation of duties	High
A.5.23 Application Security	Patch mgmt & secure configs	Partially Compliant	Workstations unpatched	Implement patch mgmt	High
A.5.29 Service Availability	Continuity for cloud ERP	Partially Compliant	No offline ERP plan	Create offline workflows	Medium

Clause / Control	Requirement	Current Status	Gap Description	Recommended Action	Priority
A.5.30 Backup Management	Backup & restore testing	Partially Compliant	No restore testing	Quarterly restore tests	Medium
A.6.3 Awareness Training	Mandatory training	Non-Compliant	No training; phishing incidents	Conduct cyber awareness	High
A.6.6 Supplier Security	Vendor risk evaluation	Partially Compliant	No vendor security checks	Implement vendor checklist	Medium
A.7.4 Physical Security Monitoring	Protection of assets	Partially Compliant	Exam papers vulnerable; no environmental controls	Secure exam storage + access logs	High
A.7.5 Protection of Assets	Physical asset protection	Partially Compliant	Fire/water protection missing	Digitize & store securely	Medium
A.8.2 Access Control Policy	Documented access rules	Non-Compliant	No access policy; weak passwords	Create Access Control Policy	High
A.8.7 Malware Protection	Anti-malware & updates	Partially Compliant	Antivirus outdated	Auto-update AV	Medium
A.8.9 Configuration Mgmt	Secure configs	Partially Compliant	Switch configs not hardened	Harden configs & backup	Medium
A.8.10 Removable Media	USB restrictions	Non-Compliant	USB ports open → data theft	Block USB, whitelist devices	High
A.8.11 Encryption	Encrypt sensitive assets	Non-Compliant	Laptops & payroll not encrypted	BitLocker + folder encryption	High

Clause / Control	Requirement	Current Status	Gap Description	Recommended Action	Priority
A.8.12 Email Security	Anti-phishing	Partially Compliant	Limited filtering	Enable advanced filtering	High
A.8.13 Data Backup	Secure backup processes	Partially Compliant	Backups untested	Perform restore tests	Medium
A.8.14 Logging & Monitoring	Logs must be reviewed	Non-Compliant	Logs collected but NEVER reviewed	Monthly log review	High
A.8.16 Monitoring Activities	Audit trails	Partially Compliant	ERP logs insufficient	Enable full ERP logging	High
A.8.20 Network Security	WPA3, segmentation	Partially Compliant	Weak Wi-Fi password	Implement WPA3 & MAC filtering	Medium
A.8.23 Password Policies	Password rules & lockout	Non-Compliant	No lockout threshold	Enable auto-lockout	High
A.8.24 Data Leakage Prevention	DLP needed	Non-Compliant	No DLP; cloud sharing unsafe	Implement DLP & sharing restrictions	High
A.8.25 + A.8.26 Dev Security	Secure development	Not Applicable	No software development in scope	Not required	Low
A.8.28 Confidential Data Handling	Handling sensitive data	Partially Compliant	Payroll & exam papers insecure	Encrypt + secure storage	High
A.8.31 Vulnerability Mgmt	Patching & scanning	Partially Compliant	Patch delays & weak scanning	Vulnerability mgmt program	Medium

Clause / Control	Requirement	Current Status	Gap Description	Recommended Action	Priority
A.9.4 Identity Systems (MFA)	MFA required	Non-Compliant	Staff email lacks MFA	Enforce MFA	Critical

5. Key High-Priority Gaps (Updated Summary)

1. No MFA for ERP & email
 2. USB ports fully open → high exfiltration risk
 3. Exam paper storage insufficiently protected
 4. Laptops & payroll files unencrypted
 5. Weak phishing defenses & no training
 6. No Access Control Policy
 7. ERP logs & system logs not reviewed
 8. Cloud misconfigurations (OneDrive public sharing)
 9. Vendor verification gaps
 10. Unlicensed software installed in Lab
 11. Weak Wi-Fi security (WPA2 only)
-

6. Updated Remediation Plan

Priority Required Actions

High MFA, encryption, USB blocking, phishing training, RBAC, secure exam storage, cloud security, log review

Medium Backup testing, network hardening, vendor review, digitization

Low Annual policy refreshers

7. Conclusion

The updated gap analysis reveals **major improvements needed** in authentication, physical security (exam paper handling), cloud storage configuration, logging, and user behavior management.

Implementing recommended controls will significantly reduce risks including **data leakage, fraud, ransomware, unauthorized access, and exam integrity issues**.